

# Encryption Requirements Overview

CompTIA SecAI+: AI Security Certification Complete Exam Prep 2026 | Section 13: Data Security Controls

## 1. The Three States of Data: A Security Framework

---

Before selecting encryption controls, practitioners must understand the three fundamental states in which data can exist: at rest, in transit, and in use. Each state has distinct characteristics, attack surfaces, and corresponding protection mechanisms. Data at rest resides on persistent storage — hard drives, SSDs, databases, backup tapes, object storage buckets. Data in transit moves across networks — between services, between users and systems, between data centres. Data in use is actively loaded into processor memory for computation. A robust encryption strategy addresses all three states, because a single unprotected state creates a gap that adversaries can exploit.

- Data at rest — stored on persistent media; vulnerable to physical theft, improper disposal, and unauthorised storage access.
- Data in transit — moving across networks; vulnerable to interception, man-in-the-middle attacks, and network sniffing.
- Data in use — loaded into RAM for processing; vulnerable to memory dumps, insider threats, and hypervisor-level access.
- A comprehensive encryption programme protects all three states — securing two out of three still leaves a material attack surface.

## 2. Symmetric Encryption: AES and the Key Management Challenge

---

Symmetric encryption uses a single shared key for both encryption and decryption. The Advanced Encryption Standard with a 256-bit key (AES-256) is the current gold standard for symmetric encryption and is approved by NIST for protecting classified US government information up to SECRET level. AES-256 is computationally efficient, making it the preferred choice for bulk data encryption — entire databases, file systems, disk volumes, and backup archives.

The fundamental challenge of symmetric encryption is key distribution and protection. Any party that possesses the key can decrypt all data protected by that key. This creates a critical dependency: the security of all encrypted data rests entirely on the security of the key. For AI systems handling sensitive training data, model weights, or inference outputs, this means that key management is not a secondary concern — it is equal in importance to the encryption algorithm itself.

**Key management principle:** The encryption key must never be stored alongside the encrypted data. An attacker who compromises the storage medium must not automatically gain access to the key. Use dedicated key management services (AWS KMS, Azure Key Vault, Google Cloud KMS) and separate the key from the data it protects.

## 3. Asymmetric Encryption: Public-Key Infrastructure in AI Contexts

---

Asymmetric encryption uses mathematically linked key pairs: a public key that anyone can possess and use to encrypt data, and a private key that only the owner holds and uses to decrypt. RSA and elliptic curve cryptography (ECC) are the most widely deployed asymmetric algorithms. Because asymmetric operations are computationally expensive relative to symmetric operations, they are typically not used to encrypt large data volumes directly.

In practice, asymmetric and symmetric encryption are combined in a hybrid model: asymmetric encryption is used to securely exchange a symmetric session key, and that symmetric key then encrypts the bulk data. TLS — the protocol securing all HTTPS traffic and most AI service communications — implements exactly this hybrid model. Understanding this distinction is essential for SecAI+ exam scenarios that ask which algorithm type to apply to a given data protection requirement.

| Property       | Symmetric (AES)                                   | Asymmetric (RSA/ECC)                           |
|----------------|---------------------------------------------------|------------------------------------------------|
| Key structure  | Single shared key                                 | Public/private key pair                        |
| Speed          | Very fast; hardware-accelerated                   | Slow; computationally expensive                |
| Typical use    | Bulk data encryption (disks, databases, files)    | Key exchange, digital signatures, certificates |
| Key challenge  | Secure key distribution                           | Private key protection; certificate management |
| AI application | Encrypting training datasets, model weights, logs | Securing API authentication, TLS handshakes    |

## 4. Regulatory Requirements: What Compliance Demands

Encryption is no longer optional for organisations handling regulated data. Multiple global frameworks impose specific encryption requirements, and AI systems frequently process data categories that fall under several frameworks simultaneously — a healthcare AI model, for example, may be subject to HIPAA, GDPR, and SOC 2 requirements concurrently.

- **GDPR (EU):** Requires 'appropriate technical measures' to protect personal data. Regulators consistently interpret this to include strong encryption for stored and transmitted personal data. Failure to encrypt data that is subsequently breached is treated as an aggravating factor in penalty assessments.
- **HIPAA (US Healthcare):** Explicitly identifies encryption as an addressable safeguard for electronic protected health information (ePHI). While technically 'addressable' rather than 'required', organisations that choose not to encrypt must document equivalent alternative measures — in practice, encryption is the standard.
- **PCI-DSS (Payment Card Industry):** Mandates encryption of cardholder data at rest (Requirement 3) and in transit (Requirement 4). Specifies that encryption algorithms must use strong cryptography, defined as AES-128 or higher.
- **NIST SP 800-111 and FIPS 140-2/140-3:** US government standards specifying approved encryption algorithms and validated cryptographic modules. AI systems deployed in federal contexts must use FIPS-validated implementations.

**Real-World Incident — Morgan Stanley Data Disposal (2022):** Morgan Stanley was fined \$35 million by the

SEC after decommissioned server hardware containing unencrypted client data was auctioned without proper data sanitisation. Hard drives were sold at auction without wiping or encryption. This case illustrates that encryption at rest must extend to the full data lifecycle, including hardware retirement — not merely active production systems. AI training hardware reaching end-of-life carries the same risk if training data was stored unencrypted.

## 5. Key Management: The Linchpin of Effective Encryption

Encryption is only as strong as the key management practices supporting it. An organisation can implement AES-256 correctly on every system and still suffer a data breach if keys are managed carelessly. Key management encompasses the entire key lifecycle: generation, storage, distribution, rotation, revocation, and destruction.

- **Generation:** Keys must be generated using cryptographically secure random number generators (CSPRNG). Weak entropy in key generation can make keys predictable and susceptible to brute-force attacks.
- **Storage:** Keys must be stored separately from the data they protect, in dedicated key management services or hardware security modules (HSMs). Never store keys in application code, configuration files, or environment variables without additional protection.
- **Rotation:** Keys should be rotated on a defined schedule — typically every 90 days to one year depending on data sensitivity — to limit the exposure window if a key is compromised without detection.
- **Revocation:** The ability to revoke keys quickly when compromise is suspected is critical. Key revocation must be tested before it is needed in an incident.
- **Destruction:** At end-of-life, keys must be securely destroyed using procedures that prevent reconstruction. Cryptographic erasure — destroying the key rather than overwriting data — is the most efficient method for large encrypted datasets.

## 6. Cloud Provider Encryption: Options and Trade-offs

Cloud providers offer multiple encryption models, each with different control and trust characteristics. Understanding these options is essential for AI security practitioners evaluating cloud-hosted AI workloads.

| Model                                     | Who Manages the Key     | Trust Level                              | Typical Use Case                                          |
|-------------------------------------------|-------------------------|------------------------------------------|-----------------------------------------------------------|
| Provider-managed keys (SSE-S3, SSE-Azure) | Cloud provider          | Trust the provider's key management      | General-purpose workloads; simplest implementation        |
| Customer-managed keys (CMK)               | Customer, via cloud KMS | Provider encrypts; customer controls key | Regulated industries; need for key revocation authority   |
| Customer-provided keys (SSE-C, BYOK)      | Customer's own HSM/KMS  | Maximum customer control                 | Highly sensitive data; regulatory separation requirements |

|                        |                         |                                |                                                      |
|------------------------|-------------------------|--------------------------------|------------------------------------------------------|
| Client-side encryption | Customer, before upload | Zero cloud-provider visibility | Ultra-sensitive data; multi-cloud; compliance-driven |
|------------------------|-------------------------|--------------------------------|------------------------------------------------------|

For AI systems processing sensitive training data or inference inputs, customer-managed keys (CMK) represent a practical balance: the cloud provider handles encryption operations efficiently while the customer retains authority to revoke key access — which immediately renders all encrypted data inaccessible, even to the provider. This capability is particularly important for GDPR right-to-erasure obligations where large datasets cannot be practically overwritten.

## 7. End-to-End Encryption in AI System Architectures

---

End-to-end encryption (E2EE) ensures that data is encrypted from the point of origin through to the point of consumption, with no intermediate system able to access plaintext. In AI contexts, true E2EE is technically demanding because AI inference typically requires plaintext data for computation — the model cannot process what it cannot read.

Practical approaches to approximating E2EE in AI architectures include using secure enclaves (confidential computing) at the inference endpoint, implementing federated learning to avoid centralising sensitive training data, and combining TLS for transport with application-layer encryption for field-level sensitivity. The SecAI+ exam tests whether candidates understand that 'encrypting data in transit' and 'end-to-end encryption' are not synonymous — TLS alone does not provide E2EE if intermediate services decrypt and re-encrypt at each hop.

## 8. Performance Considerations and Hardware Acceleration

---

A common organisational objection to comprehensive encryption is performance impact. Modern hardware substantially eliminates this concern. Intel and AMD processors since approximately 2010 include AES-NI (AES New Instructions), dedicated hardware circuitry that accelerates AES operations by a factor of 5 to 10 compared to software implementation. SSDs frequently include encryption controllers that encrypt data transparently at wire speed with no measurable throughput reduction.

The realistic performance overhead for AES-256 encryption at rest on modern hardware is 1 to 5 percent. Network encryption via TLS 1.3 on hardware with AES-NI adds negligible latency for most workloads. AI inference workloads that have legitimate performance constraints should be benchmarked with encryption enabled — in the majority of cases, the measurable impact is within acceptable tolerances. Performance concerns should not be the basis for deferring encryption controls without empirical testing.

## 9. What Encryption Does Not Protect Against

---

A critical exam topic — and a common organisational misconception — is the scope of protection that encryption actually provides. Encryption protects data confidentiality from parties who do not possess the key. It does not:

- Protect against authorised access — an attacker who compromises valid credentials can access encrypted data exactly as a legitimate user would; encryption cannot compensate for weak access controls.
- Prevent data integrity attacks — encryption does not detect or prevent modification of encrypted data unless combined with authentication (AEAD modes such as AES-GCM include integrity checking; AES-CBC alone does not).
- Hide metadata — encryption conceals content but not the fact that communication is occurring, its timing, volume, or endpoint identifiers; traffic analysis remains possible.
- Protect against memory-level attacks — data decrypted into RAM for processing is vulnerable to memory dump attacks, cold boot attacks, and hypervisor-level inspection (addressed by confidential computing, covered in Lecture 64).
- Replace access controls, monitoring, or backup procedures — encryption is one layer in a defence-in-depth architecture, not a substitute for complementary controls.

**Exam alert:** Questions that describe a data breach involving authorised credential compromise, memory dumps, or metadata analysis are not testing encryption — they are testing whether you understand encryption's boundaries. Selecting 'implement stronger encryption' as the answer to an access control failure is a common distractor.

## 10. Analogy: Encryption as a Safe, Not a Guard

A useful mental model: encryption is like placing valuables in a safe. The safe protects the contents from anyone without the combination, but it does not prevent an authorised combination-holder from accessing them, does not stop someone from stealing the safe entirely (though they cannot open it), and does not prevent tampering with the safe's exterior. The lock protects confidentiality — it does not replace a security guard (access controls), a camera (monitoring), or insurance (backup and recovery). An organisation that locks everything in safes but gives the combination to everyone with a company badge has implemented encryption correctly but access controls incorrectly.

## Key Terms Glossary

| Term                       | Definition                                                                                                                                                  |
|----------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------|
| AES-256                    | Advanced Encryption Standard with a 256-bit key; the current gold standard for symmetric encryption of bulk data, approved by NIST for government use.      |
| Asymmetric encryption      | Encryption using a public/private key pair; the public key encrypts, the private key decrypts. Used for key exchange and digital signatures, not bulk data. |
| Customer-managed key (CMK) | An encryption key stored in a cloud key management service under the customer's control; the cloud provider encrypts but cannot access the key.             |
| FIPS 140-2/140-3           | US federal standards specifying requirements for cryptographic modules; required for encryption implementations in US government and regulated contexts.    |

|                                |                                                                                                                                              |
|--------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------|
| Hardware Security Module (HSM) | A physical device designed specifically to generate, store, and manage cryptographic keys with tamper-resistant hardware protection.         |
| Key rotation                   | The practice of replacing cryptographic keys on a defined schedule to limit the exposure window of a compromised key.                        |
| Symmetric encryption           | Encryption using a single shared key for both encryption and decryption; fast and efficient for bulk data encryption.                        |
| TLS (Transport Layer Security) | The protocol providing encryption for data in transit; TLS 1.3 is the current version and preferred standard for all network communications. |

## Quick Revision Checklist

- Identify the three data states (at rest, in transit, in use) and the primary encryption control for each.
- Distinguish symmetric (AES) from asymmetric (RSA/ECC) encryption, and explain when each is used.
- State why hybrid encryption (asymmetric for key exchange, symmetric for data) is the standard pattern.
- Name the regulatory encryption requirements under GDPR, HIPAA, and PCI-DSS.
- Explain the key management principle that keys must be stored separately from encrypted data.
- List the components of the key management lifecycle: generation, storage, rotation, revocation, destruction.
- Describe the difference between provider-managed, customer-managed, and customer-provided cloud encryption keys.
- Identify what encryption does NOT protect against: authorised access, integrity attacks without AEAD, metadata, memory-level attacks.
- Know that AES-NI hardware acceleration makes at-rest encryption performance overhead typically 1 to 5 percent on modern hardware.
- Recognise that end-to-end encryption and TLS-in-transit encryption are not synonymous in AI architectures.

## 10 Exam-Based MCQs — Encryption Requirements

*Test yourself after reading. These questions are written in real exam style — scenario-heavy, with plausible distractors. Read every explanation, including for questions you answered correctly.*

**Q1. Scenario:** A healthcare technology company is deploying an AI diagnostic assistant in Azure. Their CISO has specified that the company must retain the ability to immediately terminate the cloud provider's access to patient data without deleting the data itself — a requirement driven by a contract clause in their hospital client agreements. An AI security architect is reviewing a proposed deployment where a machine learning inference service will process patient medical records in a HIPAA-covered cloud environment. The cloud provider offers three encryption options: provider-managed keys, customer-managed keys (CMK), and client-side encryption. Which option BEST supports the organisation's ability to immediately revoke the cloud provider's access to patient data if required?

- A) Provider-managed keys — simplest to implement and fully HIPAA-compliant
- B) Customer-managed keys (CMK) — customer controls key revocation while provider handles encryption operations
- C) Client-side encryption — data is encrypted before upload, giving maximum control
- D) No encryption is needed if access controls are sufficiently strong

**Answer: B** **Explanation:** B is correct because CMK gives the customer authority to revoke the key through the cloud key management service, immediately making all CMK-encrypted data inaccessible to the provider — this is the specific capability the scenario requires. C (client-side) also provides this control but adds significant operational complexity and may not be practical for real-time inference workloads. A is incorrect because provider-managed keys cannot be unilaterally revoked by the customer. D is incorrect because access controls and encryption serve different security functions; encryption protects against scenarios where access controls fail or the provider itself is compromised.

**Q2. Scenario:** A junior engineer set up the encryption configuration during an initial deployment and chose to store the AES-256 key in a .env file in the same S3 bucket as the encrypted training data for 'ease of access'. The configuration has been in place for six months. During a security assessment of an AI training pipeline, an analyst discovers that AES-256 encryption is implemented on the training data stored in cloud object storage, but the encryption keys are stored in a configuration file in the same S3 bucket as the encrypted data. What is the PRIMARY security risk this creates?

- A) AES-256 is not a strong enough algorithm for training data and should be replaced with AES-512
- B) An attacker who gains read access to the bucket obtains both the encrypted data and the key, eliminating the protection encryption was meant to provide
- C) Storing keys in configuration files reduces performance due to increased I/O overhead
- D) The configuration file may be indexed by search engines, exposing the key to web scraping

**Answer: B** **Explanation:** B is correct because encryption's security guarantee depends on the key being inaccessible to an attacker who compromises the storage medium. Co-locating keys and encrypted data eliminates this guarantee — the attacker has everything needed to decrypt. A is incorrect; AES-256 is the current gold standard and AES-512 is not a standard algorithm. C is incorrect; key storage location has negligible performance impact. D is incorrect and describes a different attack scenario that would require the bucket to be publicly readable.

**Q3. Scenario:** The junior analyst's credentials had access to read the entire training dataset as part of their role. The attacker used phishing to obtain the credentials and accessed the dataset through the normal API. A financial services company's AI fraud detection system was breached when an attacker used stolen credentials from a junior analyst to access and exfiltrate the model's training dataset. The dataset was encrypted at rest with AES-256 and customer-managed keys. The CISO states that the breach 'proves encryption is ineffective'. Which response MOST accurately addresses the CISO's conclusion?

- A) The CISO is correct — the breach demonstrates that AES-256 is insufficient for financial data and should be replaced with a stronger algorithm

- B) The CISO is incorrect — encryption at rest protects against physical theft and unauthorised storage access but does not compensate for compromised legitimate credentials; the failure was in access controls, not encryption
- C) The CISO is correct — encryption at rest should have been combined with encryption in transit to prevent the exfiltration
- D) The CISO is incorrect — customer-managed keys should have been replaced with provider-managed keys to prevent this type of breach

**Answer: B** **Explanation:** B is correct because encryption at rest protects data against parties without the key — but authorised credential holders are the key holders. When an attacker uses valid credentials, they inherit the access rights those credentials carry, including the ability to read encrypted data through the normal decryption pathway. The control failure was in credential security and access control scoping, not encryption. A is incorrect; algorithm strength is irrelevant when the attacker uses legitimate keys. C is incorrect; the exfiltration was via authenticated access, not network interception. D is incorrect; key management model does not affect this attack vector.

**Q4. Which of the following BEST describes the reason that TLS 1.3 for data in transit and AES-256 for data at rest are implemented as a hybrid encryption system rather than using RSA alone?**

- A) RSA is not approved under FIPS 140-3 for data at rest
- B) Asymmetric algorithms are computationally expensive for bulk data; the hybrid model uses asymmetric encryption only for key exchange and symmetric encryption for bulk data
- C) TLS 1.3 does not support RSA key exchange, requiring a hybrid approach
- D) AES-256 cannot encrypt keys, so RSA is required for that specific step

**Answer: B** **Explanation:** B is correct; this is the fundamental reason hybrid encryption exists. RSA operations are orders of magnitude more computationally expensive than AES for equivalent data volumes. The hybrid model is efficient: asymmetric (RSA or ECC) for secure key exchange of a small symmetric session key, then symmetric (AES) for bulk data. A is incorrect; RSA is FIPS-approved. C is partially true — TLS 1.3 deprecated RSA key exchange in favour of ephemeral Diffie-Hellman, but this is a different (related) point, not the primary reason for hybrid models. D is incorrect; AES can encrypt keys but the rationale is about performance, not capability.

**Q5. An organisation subject to PCI-DSS is building an AI model to detect payment card fraud. Which encryption requirement does PCI-DSS impose on the training dataset if it contains actual cardholder data (PANs)?**

- A) PCI-DSS has no encryption requirement for training data, only for production transaction data
- B) PCI-DSS requires strong cryptography for stored cardholder data, which includes training datasets containing real PANs
- C) PCI-DSS requires hashing, not encryption, for stored PANs in training data
- D) PCI-DSS only requires encryption if the training data contains more than 100,000 cardholder records

**Answer: B** **Explanation:** B is correct. PCI-DSS Requirement 3 mandates strong cryptography for stored

cardholder data (PANs) regardless of where or why it is stored — training datasets are not exempt. In practice, using real cardholder data in AI training is high-risk and most organisations should tokenise or anonymise PANs before use in training. A is incorrect; PCI-DSS scope covers stored PANs wherever they reside. C is incorrect; hashing renders PANs unreadable but also unusable for training — encryption with key control is the required approach for data that must remain usable. D is incorrect; PCI-DSS has no volume threshold for encryption requirements.

**Q6. Which encryption mode provides BOTH confidentiality AND integrity protection for stored AI model weights, making it preferable over AES-CBC for this use case?**

- A) AES-ECB (Electronic Codebook)
- B) AES-CBC (Cipher Block Chaining) with a separate HMAC
- C) AES-GCM (Galois/Counter Mode)
- D) AES-128 instead of AES-256

**Answer: C** **Explanation:** C is correct. AES-GCM is an Authenticated Encryption with Associated Data (AEAD) mode that provides both encryption (confidentiality) and a built-in authentication tag (integrity). An attacker who modifies the encrypted model weights will cause the authentication tag to fail, detecting the tampering. AES-CBC alone provides only confidentiality — an attacker can modify ciphertext without detection. A (AES-ECB) is incorrect and actually the weakest mode — it reveals patterns in plaintext because identical plaintext blocks produce identical ciphertext blocks. B (AES-CBC plus HMAC) can work but requires careful implementation to avoid ordering errors; AES-GCM is the cleaner solution. D is incorrect; key length does not affect whether integrity is provided.

**Q7. An AI security practitioner is advising on key rotation policy for encryption keys protecting a large language model's training data. Which rotation interval represents current best practice for high-sensitivity data?**

- A) Keys should never be rotated because rotation creates operational risk of data loss
- B) Keys should be rotated every 90 days to one year, depending on data sensitivity and regulatory requirements
- C) Keys should be rotated every five years to minimise operational overhead
- D) Key rotation is only required when a breach is confirmed — routine rotation provides no security benefit

**Answer: B** **Explanation:** B is correct. Key rotation limits the blast radius of an undetected key compromise — if a key has been silently exfiltrated, rotation limits how long it remains useful to an attacker. NIST and most compliance frameworks recommend rotation intervals of 90 days to one year for high-sensitivity applications. A is incorrect; while rotation does require careful procedures, the operational risk is manageable and is significantly outweighed by the security benefit. C is a five-year interval that is far too long for sensitive data. D is incorrect; routine rotation provides the specific benefit of limiting exposure windows from undetected compromise.

**Q8. Which statement MOST accurately describes the role of hardware AES-NI instructions in modern AI security deployments?**

- A) AES-NI is a software library that must be separately licensed and installed
- B) AES-NI provides hardware-accelerated AES operations, reducing the performance overhead of encryption to typically 1 to 5 percent on modern processors
- C) AES-NI replaces the need for key management systems by managing keys in hardware
- D) AES-NI only supports AES-128 and cannot accelerate AES-256 operations

**Answer: B** **Explanation:** B is correct. AES-NI is built into modern Intel and AMD processor silicon and executes AES operations in dedicated hardware circuitry approximately 5 to 10 times faster than software implementations. This virtually eliminates the performance argument against encrypting AI workloads. A is incorrect; AES-NI is a CPU feature, not a software library. C is incorrect; AES-NI handles computation, not key management. D is incorrect; AES-NI supports both AES-128 and AES-256.

**Q9. *Scenario:*** A streaming company uses petabytes of user behavioural data to train recommendation AI models. Users are exercising GDPR deletion rights, and the data engineering team estimates that physically overwriting individual records across the distributed storage system would take weeks per user. An organisation plans to use GDPR right-to-erasure to respond to user deletion requests for AI training data stored in a large distributed object storage system. Which encryption-related approach makes this operationally feasible without overwriting petabytes of stored data?

- A) Re-encrypting all stored data with a new key that excludes the deleted user's records
- B) Cryptographic erasure — destroying the encryption key for a data segment, rendering the data permanently inaccessible without physically deleting it
- C) Deleting the user's record from the index file while leaving encrypted data intact
- D) GDPR does not apply to training data, so no deletion mechanism is required

**Answer: B** **Explanation:** B is correct. Cryptographic erasure is the recognised approach for large-scale data deletion compliance: data is encrypted with per-user or per-data-segment keys, and fulfilling a deletion request means destroying that segment's key. The encrypted data persists but is permanently unreadable without the key — regulators accept this as equivalent to deletion when the key destruction is verifiable. A is technically possible but impractical at petabyte scale. C is incorrect; metadata deletion does not constitute erasure of the underlying data. D is incorrect; GDPR right-to-erasure applies to personal data in training sets.

**Q10. A SecAI+ candidate is reviewing a scenario where an AI system's training data was breached through a SQL injection attack that allowed the attacker to execute queries through the application layer. The data was encrypted at rest with AES-256. Why did the encryption NOT prevent the breach?**

- A) AES-256 is vulnerable to SQL injection attacks
- B) The SQL injection attack exploited the application layer, which accesses data through the normal decryption pathway — the attacker read plaintext data as the application would
- C) Encryption at rest only protects against physical theft, not network-based attacks
- D) The attacker must have also stolen the encryption keys from the key management service

**Answer: B** **Explanation:** B is correct. The application layer decrypts data for use — SQL injection exploits the application's own database access mechanism, so the attacker reads data through the same decryption pathway the application uses. Encryption at rest does not protect against attacks that succeed at the application or data access layer. C is partially true but incomplete — at-rest encryption protects against storage-level attacks, which include some but not all network-based attacks. A is incorrect; AES-256 is not vulnerable to SQL injection. D is possible in theory but unnecessary when the application itself provides access to decrypted data.